PROJECT REPORT — PART ONE

تصميم نظام توثيق امن بدون كلمة مرور لأجهزة انترنيت الأشياء باستخدام FIDO2 Passkeys

Scientific Problem • State of the Art • Proposed Solution • Theoretical Background

- الطلاب : ساره الحاج علي , الاء صالح
- المشرف : د.محمد الشايطة , م.جعفر محفوض

Document Structure

- 1. Scientific Problem and Project Objectives
- 2. State of the Art
- 3. Proposed Solution
- Chapter 1. Theoretical Background
- References to Be Verified

Draft status: This report has been revised using the three supplied papers. The research gap is a candidate gap derived from this limited set of sources, not a claim of proven novelty across all literature. The protocol, implementation, and security evaluation remain proposed work; results must be added only after the prototype and ProVerif model have actually been tested.

1. Scientific Problem and Project Objectives

1.1 Scientific Problem

The Internet of Things (IoT) has become an important part of modern digital infrastructure. IoT devices, such as smart cameras, sensors, and connected appliances, communicate with servers and cloud platforms to provide different services. As the number of connected devices increases, securely registering and managing these devices becomes an important security challenge.

Device onboarding is the process of registering a new device with a system or service and establishing the necessary trust relationships. During this process, the system must ensure that the user is authorized to register the device and that the device itself is legitimate.

FIDO2 Passkeys provide a passwordless authentication mechanism based on public-key cryptography. However, authenticating the user does not automatically establish the cryptographic identity of an IoT device. A secure onboarding procedure must therefore consider both user authorization and device authentication.

Potential threats include device impersonation, unauthorized device registration, and replay attacks involving previously exchanged messages. The relevance of these threats and the effectiveness of existing countermeasures must be evaluated against the specific protocol being studied.

The research question investigated in this project is:

> **How can an IoT onboarding protocol integrate FIDO2 Passkey authentication with cryptographic verification of device identity to reduce unauthorized device registration and resist selected attacks, while allowing its security properties to be formally analyzed?**

1.2 Project Aim

The main aim is to design and evaluate a secure IoT onboarding protocol that combines user authentication using FIDO2 Passkeys with cryptographic verification of IoT device identity.

The proposed approach will be assessed through a software prototype, controlled security tests, and formal analysis using ProVerif, subject to the assumptions and capabilities of the formal model.

1.3 Project Objectives

1. Study FIDO2 Passkeys, IoT onboarding, and security mechanisms used in existing onboarding frameworks.
2. Review related research and identify a specific security limitation that can be investigated.
3. Design a protocol that combines user authentication with cryptographic device identity verification.

4. Bind the user's authorization to the particular device and onboarding session being registered.
5. Implement a software prototype that simulates the proposed protocol.
6. Evaluate the protocol against selected attacks, particularly device impersonation and replay attacks.
7. Model the protocol in ProVerif and analyze relevant properties, such as authentication and resistance to replay.
8. Discuss experimental results, assumptions, limitations, and possible future improvements.

1.4 Project Scope

The project will focus on the design and evaluation of a secure IoT onboarding protocol. The initial implementation will use a software-based simulation rather than requiring physical IoT hardware. The main components will include a user, an IoT device, an onboarding server, and a FIDO2-based authentication mechanism.

The project will focus on two principal attack scenarios:

- Device impersonation: an unauthorized device attempts to register by claiming to be a legitimate device.
- Replay attacks: an attacker attempts to reuse previously exchanged messages to repeat an operation or bypass a security check.

The project will also investigate how user authorization is associated with the intended device. It will not attempt to eliminate every possible threat; instead, it will define and evaluate a limited set of security properties.

2. State of the Art

2.1 Introduction

Secure authentication and IoT onboarding have been investigated through several approaches, including passwordless authentication, token-based authorization, and device-registration frameworks. This section summarizes three research directions relevant to the proposed project.

2.2 FIDO2-Based Passkey Authentication with JWT

Yusop, Kamarudin, and Hasan propose a seamless passwordless authentication model that combines FIDO2 passkeys with JSON Web Tokens (JWTs) to let users access multiple applications in the same domain without repeated authentication. The paper reports formal security analysis using ProVerif and a prototype with sample applications. Its principal problem is cross-application user access; it does not primarily design a protocol for registering an IoT device while independently verifying that device's cryptographic identity [1].

This study is therefore relevant to the user-authentication and formal-analysis parts of the project, but it does not by itself establish how a user's approval should be cryptographically bound to a particular IoT device and onboarding transaction. The bibliographic details have been checked against the supplied conference paper [1].

2.3 Systematic Review of Passwordless Authentication

Yusop et al. provide a systematic review of passwordless authentication methods, including biometrics, security keys, token-based systems, and FIDO2. The review discusses security and privacy, usability, interoperability, implementation cost, scalability, and reliability. Its future directions include stronger real-world evaluation, scalability improvements, further security analysis, and improved usability [2].

This paper supplies context and motivates careful security evaluation, but it is a broad review rather than a protocol specifically designed to bind user authentication to the cryptographic identity of one IoT device during onboarding [2].

2.4 OAuth 2.0-Based IoT Onboarding

Ito proposes a semi-automated IoT onboarding framework based on the OAuth 2.0 Device Authorization Grant. A key design choice is that device ownership need not be pre-registered, which improves flexibility but creates security trade-offs. The paper evaluates a prototype with five devices, analyzes onboarding time, discusses threats such as session spying, stolen access tokens, remote phishing, and malicious-device onboarding, and considers an alternative using FIDO2 standards [3].

This is the closest of the three supplied papers to the project's application domain. Importantly, Ito discusses that a rogue device may report spoofed device attributes and identifies device attestation—where the device signs its attributes using a manufacturer-provisioned private key—as a possible extension. The paper also discusses the difficulty of combining stronger security with a simple and efficient onboarding process [3].

Therefore, the project must not claim novelty merely because it combines FIDO2 and IoT onboarding. The more specific candidate contribution is to design and evaluate a protocol that binds (i) a successful user authentication, (ii) proof that the intended device possesses the private key associated with a trusted device certificate, and (iii) a fresh, single onboarding transaction

2.5 Comparative Analysis

Criterion	FIDO2 + JWT model [1]	Systematic review [2]	OAuth 2.0 IoT onboarding [3]	Proposed project
Main focus	Seamless user access across multiple applications	Survey of passwordless methods, challenges, and future directions	Semi-automated IoT onboarding using OAuth 2.0 Device Authorization Grant	Secure onboarding with separate user and device verification
FIDO2 relevance	Core user authentication mechanism	Discussed as one passwordless standard	Discusses a FIDO2-based alternative to device authorization	FIDO2 authentication is simulated for the user side
Device identity	Not the main focus of the model	Broad review; no single device-onboarding protocol	Discusses device attributes and device attestation as a possible extension	CA-issued device certificate plus proof of possession
Security evaluation	Reports ProVerif analysis and prototype evaluation	Reviews findings from selected studies; recommends further evaluation	Prototype with five devices and analysis of onboarding threats	Planned attack tests and ProVerif model; results not yet available
Limitation relevant here	Focuses on cross-application access, not IoT device registration	Broad survey cannot prove a specific protocol gap	No pre-registered ownership; discusses risks and possible attestation extension	Must demonstrate whether transaction binding adds measurable/formal security value

2.6 Preliminary Research Gap

The three reviewed papers address related but different problems. The FIDO2–JWT study focuses on seamless authentication across applications and uses ProVerif for formal security analysis [1]. The systematic review surveys passwordless methods and highlights broad challenges and future research directions, including real-world evaluation, scalability, and security analysis [2]. The IoT onboarding framework focuses on OAuth 2.0 device authorization and explicitly discusses malicious-device onboarding and device attestation as a possible extension [3].

Based on this comparison, a candidate research gap for this project is the need to specify and formally evaluate how user authentication, device identity verification, and authorization for one particular onboarding transaction are bound together. The target is not to claim that device attestation or FIDO2 in IoT onboarding is new; Ito already discusses device attestation and a FIDO2-based alternative [3]. Instead, the project will investigate a clearly defined certificate-based proof-of-possession protocol and test whether it rejects device impersonation and replay under explicit assumptions.

The proposed design will simulate FIDO2-based user authentication and independently verify the IoT device using a CA-issued certificate and a signature over a fresh server challenge, device identifier, and transaction identifier. The server will accept registration only when the certificate is trusted, proof of possession succeeds, the challenge has not been used, and the user authorization and device evidence refer to the same transaction. This is a project hypothesis to test, not a result already demonstrated by the literature.

3. Proposed Solution

3.1 Overview

The proposed solution is a secure IoT onboarding protocol combining user authentication with cryptographic device identity verification. The system is intended to ensure that a device is registered only after the user has been authenticated and the device has demonstrated possession of an appropriate cryptographic credential.

The design will bind authorization and device-verification evidence to the same onboarding transaction. A software prototype will be used to evaluate the protocol against selected attack scenarios.

3.2 Main System Components

User: initiates the onboarding process and authorizes registration of an IoT device.

FIDO2 authentication mechanism: authenticates the user using a registered credential.

IoT device: possesses a device-specific private key and a certificate that associates its device identity with the corresponding public key. During onboarding, it proves possession of the private key.

Certificate Authority (CA): issues a certificate that binds an approved device identity to its public key. The prototype must state how the device identity is approved before certificate issuance.

Onboarding server: verifies the user's FIDO2 authentication result, validates the device certificate and proof of possession, checks freshness, and binds all evidence to one onboarding transaction.
ProVerif model: represents the protocol and analyzes selected security properties under explicit assumptions.

3.3 High-Level System Flow

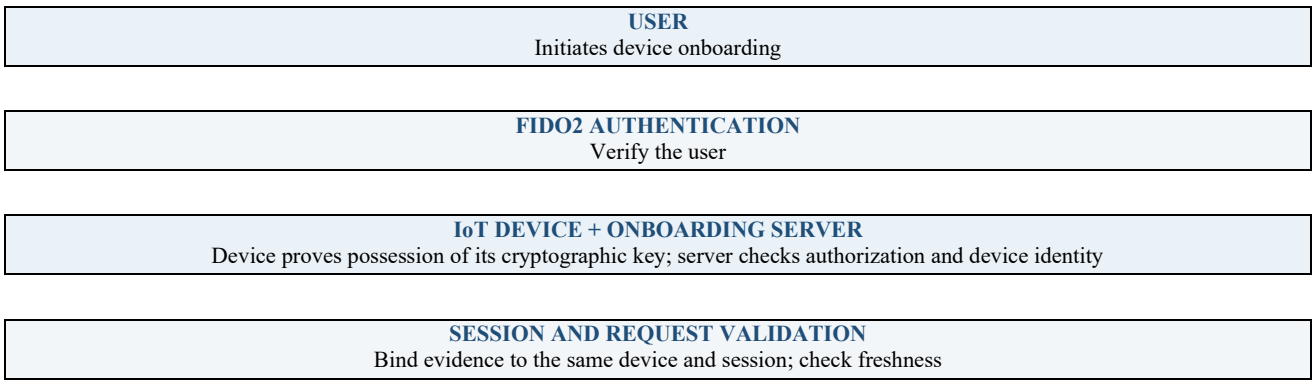




Figure 1. Structural workflow of the proposed IoT onboarding protocol.

Figure 2. Preliminary flow of the proposed onboarding process.

Chapter 1. Theoretical Background

1.1 Introduction

This chapter introduces the concepts required to understand the proposed secure IoT onboarding protocol: the Internet of Things, authentication and authorization, FIDO2 Passkeys, IoT onboarding, cryptographic mechanisms, security threats, and formal verification using ProVerif.

1.2 Internet of Things

1.2.1 Definition

The Internet of Things refers to interconnected physical devices equipped with technologies that allow them to collect, process, exchange, or act on data. Examples include smart cameras, environmental sensors, industrial monitoring devices, and connected household appliances. IoT systems commonly include physical devices, communication networks, application servers, and cloud services.

1.2.2 Security Challenges in IoT

IoT devices may have limited processing power, memory, energy, or user-interface capabilities. Some devices remain deployed for long periods and may be difficult to update or manage. These characteristics create challenges for authentication, credential management, secure communication, and access control. A secure IoT system must consider both user identity and the identity of participating devices.

1.3 Authentication and Authorization

1.3.1 Authentication

Authentication is the process of verifying the identity of an entity, such as a user, device, or service. It answers the question: who or what is communicating with the system?

1.3.2 Authorization

Authorization determines which actions an authenticated entity is permitted to perform. A user may authenticate successfully but still lack permission to register a particular device. Authentication and authorization are distinct security functions.

1.3.3 User Authentication and Device Authentication

User authentication verifies the person requesting an operation. Device authentication verifies that a communicating device possesses a credential associated with an accepted device identity. Successfully authenticating a user does not automatically prove the identity of the device being registered.

1.3.4 Mutual Authentication

Mutual authentication occurs when two communicating parties authenticate each other. In an IoT context, a protocol may need to establish that a device is legitimate and that the server it communicates with is the intended server. The exact requirements depend on the system architecture and threat model.

1.4 FIDO2 Passkeys

1.4.1 Overview

FIDO2 is a set of standards supporting strong authentication, including passwordless authentication through public-key cryptography. Its main components are Web Authentication (WebAuthn) and the Client to Authenticator Protocol (CTAP). WebAuthn defines interactions between a relying party and a client for registering and using public-key credentials. CTAP supports communication between a client and an external authenticator, where applicable.

1.4.2 Registration Process

During credential registration, the authenticator creates a public-private key pair for the relying party. The public key is provided to the relying party for storage, while the private key remains under the authenticator's control. The relying party stores the credential information needed to verify subsequent authentication responses. Credential storage and synchronization behavior depends on the authenticator and passkey implementation.

1.4.3 Authentication Process

During authentication, the relying party generates a challenge. The client and authenticator use it as part of the authentication operation. The authenticator produces a cryptographic response associated with the registered credential. The relying party verifies the response using the stored public key and validates the relevant protocol data. Correct challenge and context validation helps prevent reuse of an old response in a different context.

1.4.4 Security Benefits and Limitations

FIDO2 can improve authentication security through public-key credentials and relying-party binding. However, FIDO2 user authentication alone does not automatically verify the cryptographic identity of an IoT device being registered. The proposed project investigates combining user authentication with a separate device identity-verification mechanism.

1.5 IoT Onboarding

1.5.1 Definition

IoT onboarding is the process through which a device is registered with a service or management system and establishes the trust relationships and credentials needed for subsequent operation. Depending on the architecture, onboarding may involve device discovery, user authorization, device authentication, credential provisioning, and registration with a server.

1.5.2 Onboarding Participants

A typical onboarding architecture may include the device, its owner or authorized user, an onboarding server, an identity or authorization service, and other services needed to provision and manage credentials. Roles and interactions vary among frameworks.

1.5.3 OAuth 2.0 and Device Authorization

OAuth 2.0 is an authorization framework that enables a client to obtain limited access to protected resources. The OAuth 2.0 Device Authorization Grant is designed for clients with limited input capabilities or without a

convenient browser interface. OAuth 2.0 authorization should not be confused with cryptographic proof of a device's identity.

1.5.4 Security Requirements for Onboarding

- Verify the user's authority to register a device.
- Verify the device's cryptographic identity.
- Protect registration messages against unauthorized modification.
- Prevent unauthorized reuse of authentication messages.
- Bind authorization to the intended device and registration session.
- Handle credentials, tokens, and registration state securely.

1.6 Cryptographic Foundations

1.6.1 Public-Key Cryptography

Public-key cryptography uses a mathematically related public key and private key. The public key may be shared, while the private key must remain protected. In the proposed system, a device-specific key pair may establish device identity. The system must also provide a trustworthy method for associating the public key with the expected device.

1.6.2 Digital Signatures

A digital signature allows a verifier to check whether a message was signed using the private key corresponding to a public key. A valid signature can provide evidence of possession of the relevant private key and message integrity. A signature alone does not establish that the public key belongs to a legitimate device.

1.6.3 Cryptographic Hash Functions

A cryptographic hash function maps input data to a fixed-length output. Hash functions are used to derive message digests and support integrity checks. Security depends on the selected function and how it is incorporated into the protocol.

1.6.4 Nonces and Freshness

A nonce is a value intended for one-time use within a protocol context. Fresh challenges, nonces, timestamps, and session identifiers can help distinguish new requests from previously captured messages. The appropriate mechanism depends on the protocol and its operational assumptions.

1.6.5 Session Binding

Session binding associates messages and authentication results with a particular protocol session or transaction. For IoT onboarding, the protocol should ensure that user authorization cannot simply be transferred to an unrelated device or registration request.

1.7 Security Threats

1.7.1 Device Impersonation

Device impersonation occurs when an attacker attempts to make an unauthorized device appear to be legitimate. A defense requires a trustworthy association between device identity and cryptographic credentials, as well as verification that the device possesses the required private key.

1.7.2 Replay Attacks

A replay attack occurs when an attacker captures a valid message and retransmits it later to repeat an operation or bypass a security check. Fresh challenges, session binding, and appropriate request-state validation can help prevent such attacks.

1.7.3 Unauthorized Device Registration

Unauthorized registration occurs when a device is added without the required authorization. Potential causes include inadequate authorization checks, weaknesses in the registration workflow, or incorrect association between a user's approval and the intended device.

1.7.4 Man-in-the-Middle Attacks

A man-in-the-middle attacker attempts to intercept or manipulate communication between two parties. Appropriate communication security, message-integrity checks, and authentication of endpoints can reduce these risks. The extent to which this threat is addressed depends on the architecture and threat model.

1.8 Formal Verification Using ProVerif

1.8.1 Introduction

ProVerif is an automated tool for analyzing security protocols using formal methods. It can model protocol participants, communication channels, cryptographic operations, and an attacker operating under specified assumptions. The tool analyzes whether particular security properties hold in the model.

1.8.2 Modeling a Security Protocol

A protocol model describes participant roles, exchanged messages, and cryptographic operations. The model must accurately represent security-relevant behavior. Simplifications and assumptions should be documented.

1.8.3 Secrecy

Secrecy properties describe whether an attacker can obtain information that should remain confidential under the modeled assumptions. The project may investigate secrecy of selected credentials or cryptographic material if these properties are relevant to the final protocol.

1.8.4 Authentication Properties

Authentication properties examine whether protocol events occur in the required relationship between communicating parties. The model may investigate whether the server's acceptance of a registration corresponds to appropriate prior user authorization and successful device identity verification. The property must be explicitly defined in the model.

1.8.5 Limitations of Formal Verification

Formal verification results apply to the model and assumptions provided to the tool. A successful analysis does not automatically prove that an implementation is free from programming errors, configuration mistakes, side-channel attacks, or weaknesses omitted from the model. The project will therefore combine formal analysis with software-based testing.

1.9 Chapter Summary

This chapter introduced the concepts underlying the proposed project, including IoT, authentication and authorization, FIDO2 Passkeys, IoT onboarding, public-key cryptography, replay attacks, device impersonation, and formal verification. These concepts provide the theoretical basis for designing an onboarding protocol that verifies both user authorization and device identity.

References

[1] M. I. M. Yusop, N. H. Kamarudin, and M. K. Hasan, "A Unified FIDO2-Based Passkey Authentication Model for Seamless User Access," in *Proceedings of the 6th International Conference on Electrical, Communication and Computer Engineering (ICECCE)*, Istanbul, Turkey, Aug. 27–28, 2025, doi: 10.1109/ICECCE67514.2025.11257931.

[2] M. I. M. Yusop, N. H. Kamarudin, N. H. S. Suhaimi, and M. K. Hasan, "Advancing Passwordless Authentication: A Systematic Review of Methods, Challenges, and Future Directions for Secure User Identity," *IEEE Access*, vol. 13, pp. 13919–13943, 2025, doi: 10.1109/ACCESS.2025.3528960.

[3] T. Ito, "Simple and Flexible Onboarding Framework for IoT Devices Based on OAuth 2.0 Standards," *IEICE Transactions on Information and Systems*, vol. E109-D, no. 5, pp. 594–610, May 2026, doi: 10.1587/transinf.2025EDP7129.